

SkillGuard 安全扫描审计报告

面向银行测试团队的 Agent Skill 准入评估

项目	内容
扫描根目录	C:\Users\vic\Desktop\Scan-Skill-Clean\examples\skills
整体风险	CRITICAL
Skill 数量	6
扫描文件数	7
问题数量	25

风险分布

等级	数量	处置建议
CRITICAL	5	强阻断，必须完成修复或例外审批
HIGH	8	建议阻断，需安全测试或负责人复核
MEDIUM	5	纳入整改计划，评估误报与业务必要性
LOW	7	发布前清理，保持 Skill 可维护

Skill 评分概览

Skill	风险	综合	安全	结构	测试	问题
dast-scan-planner	INFO	96	100	100	80	0
norm-risk-helper	MEDIUM	77	80	85	60	4
report-sanitizer	INFO	100	100	100	100	0
risky-ui-helper	CRITICAL	32	0	85	55	21
safe-api-helper	INFO	100	100	100	100	0
security-threat-model...	INFO	96	100	100	80	0

高优先级问题清单

等级	规则	Skill	问题说明	位置
CRITICAL	FILE001	risky-ui-helper	访问或引用敏感本地凭据文件	risky-ui-helper/scrip...
CRITICAL	EXFIL001	risky-ui-helper	疑似把敏感数据通过网络发送出去	risky-ui-helper/scrip...
CRITICAL	BANK002	risky-ui-helper	疑似包含客户敏感信息或金融个人信息	risky-ui-helper/scrip...
CRITICAL	BANK001	risky-ui-helper	疑似引用银行生产环境或核心系统连接信息	risky-ui-helper/scrip...
CRITICAL	AGENT006	risky-ui-helper	可能直接执行模型或工具返回内容	risky-ui-helper/scrip...
HIGH	NET002	risky-ui-helper	疑似访问内网、localhost 或云元数据地址	risky-ui-helper/scrip...
HIGH	CMD002	risky-ui-helper	存在系统命令执行能力	risky-ui-helper/scrip...
HIGH	TEST001	risky-ui-helper	可能删除测试报告、覆盖率或调试产物	risky-ui-helper/scrip...
HIGH	DEP001	risky-ui-helper	存在全局依赖安装，可能污染开发或测试环境	risky-ui-helper/scrip...
HIGH	BANK004	risky-ui-helper	日志中可能输出敏感数据	risky-ui-helper/scrip...
HIGH	FILE002	risky-ui-helper	文件操作可能越出当前工作区	risky-ui-helper/scrip...
HIGH	META008	risky-ui-helper	Skill 文档未声明网络或接口访问能力，但实际文件中...	risky-ui-helper/SKILL...
HIGH	META010	risky-ui-helper	Skill 存在删除、数据库、依赖或流水线变更风险，但...	risky-ui-helper/SKILL...

银行测试团队落地建议

建议将生产环境连接、客户敏感信息、远程脚本执行、破坏性数据库操作设为强阻断项。HTML 报告用于逐项复核，PDF 报告用于准入审批和审计归档。

静态扫描不能替代代码评审、沙箱试运行和安全测试；所有高风险 Skill 应在无真实凭据、无生产网络访问的隔离环境中验证。